



Atividade 2

(Segurança da Informação)

Lucas Vinícius de Carvalho Ikeda

1. Introdução

A introdução da documentação abordará os principais pontos da segurança da informação, incluindo:

- **Integridade**
 - Refere-se à proteção da precisão, completude e confiabilidade dos dados e informações. Garantir a integridade dos dados é essencial para evitar alterações não autorizadas ou acidentais, garantindo a consistência e a exatidão das informações.
- **Confidencialidade**
 - Diz respeito à garantia de que as informações estão acessíveis somente às pessoas autorizadas. A confidencialidade envolve a proteção contra o acesso não autorizado, seja por indivíduos internos ou externos, garantindo que as informações confidenciais permaneçam privadas.
- **Disponibilidade**
 - Refere-se à garantia de que os sistemas, recursos e informações estejam disponíveis para os usuários autorizados quando necessário. Isso envolve medidas para evitar interrupções ou indisponibilidade dos sistemas, assegurando a continuidade das operações.
- **Autenticidade**
 - Diz respeito à verificação da identidade e origem das informações, garantindo que elas sejam autênticas e provenientes de uma fonte confiável. Isso envolve a implementação de mecanismos de autenticação, como senhas, criptografia e certificados digitais.
- **Vulnerabilidade**
 - Refere-se às fraquezas ou pontos de exposição que podem ser explorados por ameaças. Identificar e mitigar vulnerabilidades é essencial para fortalecer a segurança da informação e reduzir os riscos de ataques ou violações.
- **Ameaças**
 - São eventos, ações ou circunstâncias que possam causar danos ou comprometer a segurança da informação. As ameaças podem incluir ataques cibernéticos, malware, acesso não autorizado, desastres naturais, entre outros.

Ao abordar esses pontos principais da segurança, é possível estabelecer uma base sólida para a compreensão e implementação efetiva de medidas de segurança da informação, visando proteger os ativos e garantir a confiabilidade dos sistemas e dados.

2. PDCA na Implementação de Medidas de Segurança da Informação

Para garantir a eficácia das medidas de segurança da informação conforme as normas ISO 27001, 27002 e 27003, é essencial aplicar o ciclo PDCA em todos os processos. O PDCA é composto por quatro etapas inter-relacionadas:

2.1 Planejamento (Plan)

Nesta etapa, serão estabelecidos os objetivos, metas e estratégias de segurança da informação, levando em consideração os requisitos das normas ISO. Serão identificados os ativos de informação relevantes e os riscos associados a eles, visando desenvolver políticas, procedimentos e controles adequados para mitigar os riscos identificados.

2.2 Execução (Do)

Na etapa de execução, serão implementadas as medidas de segurança da informação definidas no planejamento. Isso inclui a adoção de controles técnicos, treinamento dos colaboradores, conscientização sobre segurança da informação e a implementação de tecnologias adequadas para proteção dos ativos de informação.

2.3 Verificação (Check)

Nesta etapa, serão realizadas avaliações e auditorias para verificar a eficácia das medidas implementadas. Serão conduzidos testes de segurança, análises de vulnerabilidade e monitoramento contínuo dos controles de segurança. Os resultados obtidos serão comparados com os objetivos estabelecidos no planejamento, permitindo identificar eventuais lacunas e oportunidades de melhoria.

2.4 Ação (Act)

Com base nos resultados da etapa anterior, serão implementadas ações corretivas para abordar as não conformidades identificadas e melhorar continuamente o sistema de gestão de segurança da informação. Serão realizadas revisões e atualizações periódicas das políticas, procedimentos e controles, levando em consideração as mudanças no ambiente de segurança e os requisitos normativos em evolução.

3. Checklist para Gestão da SGSI

A fim de garantir a efetiva gestão do Sistema de Gestão de Segurança da Informação (SGSI), é recomendável utilizar um checklist que contemple os principais aspectos a serem verificados. Alguns exemplos de itens a serem incluídos no checklist são:

- 3.1** Verificar se os logs dos sistemas estão sendo gravados e monitorados adequadamente.
- 3.2** Avaliar a existência e atualidade das políticas de segurança da informação.
- 3.3** Confirmar se foram realizadas análises de risco e tratamento dos riscos identificados.
- 3.4** Avaliar a existência de planos de contingência e recuperação de desastres.
- 3.5** Verificar se a conscientização sobre segurança da informação é realizada regularmente por meio de treinamentos e campanhas de sensibilização.

Essas são apenas algumas sugestões de itens que podem compor o checklist de gestão da SGSI, sendo importante adaptá-lo de acordo com as necessidades e particularidades da organização.

4. Instrução de Trabalho para Implementação das Medidas de Segurança da Informação

A fim de orientar os colaboradores na implementação das medidas de segurança da informação, é recomendável desenvolver instruções de trabalho claras e detalhadas. Selecionamos três exemplos de instruções de trabalho para demonstrar como elas podem ser estruturadas:

4.1 Instrução de Trabalho: Controle de Acesso Lógico:

- Esta instrução de trabalho descreverá as etapas necessárias para o controle de acesso lógico aos sistemas da organização, abrangendo o cadastro de usuários, concessão de privilégios, gerenciamento de senhas e monitoramento de acessos.

4.2 Instrução de Trabalho: Gestão de Incidentes de Segurança:

- Esta instrução de trabalho estabelecerá os procedimentos a serem seguidos em caso de identificação de incidentes de segurança da informação, descrevendo as etapas de notificação, investigação, contenção e recuperação de incidentes.

4.3 Instrução de Trabalho: Gestão de Ativos de Informação:

- Esta instrução de trabalho abordará a gestão dos ativos de informação da organização, estabelecendo os procedimentos para identificação, classificação, proteção e descarte adequado dos ativos, de acordo com sua importância e sensibilidade.

Essas instruções de trabalho devem ser elaboradas de forma clara e objetiva, com o objetivo de orientar os colaboradores sobre as melhores práticas de segurança da informação a serem seguidas em suas atividades diárias.

Lembrando que a aplicação do PDCA em todos os processos, o uso de um checklist para gestão da SGSI e a elaboração de instruções de trabalho são fundamentais para garantir a implementação efetiva das medidas de segurança da informação, de acordo com as normas ISO 27001, 27002 e 27003.